Debian 8 Hardening Checklist

Make sure that you don't blindly copy and paste anything! It's imperative for you as a problem solver to understand what each of these things does before you run them, and even then, inspect what the machine says it's going to do.

These aren't in any particular order.

DO PAM STUFF LAST! IT CAN IRREVERSIBLY SCREW YOUR IMAGE UP!

- Read the README
- Enable the firewall (ufw)

```
sudo ufw enable
```

- Check firewall rules for unauthorized inbound rules

```
sudo ufw status numbered
sudo ufw delete number
```

- Check for unauthorized admins

```
cat /etc/group | grep sudo
```

- Delete unauthorized users

```
sudo userdel -r user # Only use -r if they don't say anything against deleting the user and their files.
# Check for other undeleted home directories
cd /home
ls
```

- Optional: If you can't delete files or users

```
sudo usermod -L username
```

- Check repo list

```
cat /etc/apt/sources.list
# Look through all sources in this directory
ls /etc/apt/sources.list.d/
cat /etc/apt/sources.list.d/filename
```

- Update and upgrade the system

```
# Make sure to listen to what's happening. Something important might require your verification.
sudo apt-get update
sudo apt-get dist-upgrade -y
sudo apt-get install -f -y
sudo apt-get autoremove -y
sudo apt-get autoclean -y
sudo apt-get check
```

- Get packages to be used later in this checklist

```
sudo apt-get -V -y install firefox chkrootkit ufw gufw clamav
```

- Delete telnet

```
sudo apt-get purge telnet
```

- Enable automatic updates (credit) In the GUI set Update Manager->Settings->Updates->Check for updates:->Daily.
- Optional: If the README wants administrators to use sudo

```
sudo usermod -l root
```

- Disable login as root in sshd config

```
# Make sure openssh-server is installed before doing this.
sudo nano /etc/ssh/sshd_config
# Look for PermitRootLogin, replace "PermitRootLogin" with "PermitRootLogin no" without quotes
sudo service ssh restart
```

- Optional: If the README says it doesn't want openssh-server or ftp

```
sudo apt-get -y purge openssh-server*
sudo apt-get -y purge vsftpd*
```

- Remove common malware (credit)

```
sudo apt-get -y purge hydra*
sudo apt-get -y purge john* # John the Ripper, brute forcing software
sudo apt-get -y purge nikto* # Website pentesting
# sudo apt-get -y purge netcat* Scans open ports, installed by default?
```

- Check for prohibited files

```
# You MUST paste this into a bash or sh file to run.
for suffix in mp3 txt wav wma aac mp4 mov avi gif jpg png bmp img exe msi bat sh
do
  sudo find /home -name *.$suffix
done
```

- Optional: If your README wants it, harden VSFTPD (credit)

```
# Disable anonymous uploads
sudo sed -i '/^anon_upload_enable/ c\anon_upload_enable no' /etc/vsftpd.conf
sudo sed -i '/^anonymous_enable/ c\anonymous_enable=NO' /etc/vsftpd.conf
# FTP user directories use chroot
sudo sed -i '/^chroot_local_user/ c\chroot_local_user=YES' /etc/vsftpd.conf
sudo service vsftpd restart
```

- Enforce passwords

```
PASS_MIN_DAYS 7
PASS_MAX_DAYS 90
PASS_WARN_AGE 14
```

- Password authentication (credit)

```
# Be VERY careful running anything that edits PAM configs. You could get locked out of everything!
sudo sed -i '1 s/^/auth optional pam_tally.so deny=5 unlock_time=900 onerr=fail audit even_deny_root_account silent\n/' /etc/pam.d/c
```

- Force strong passwords (credit)

```
sudo apt-get -y install libpam-cracklib
sudo sed -i '1 s/^/password requisite pam_cracklib.so retry=3 minlen=8 difok=3 reject_username minclass=3 maxrepeat=2 dcredit=1 ucre
```

- Check the crontab for malware or unauthorized actions

```
# Do this as root and as every user.
# As you:
crontab -e
# As root:
sudo crontab -e
# As another user:
sudo su - user
crontab -e
```

- Check host and nameservers

```
# Make sure it looks something like "nameservers x.x.x.x". Try using 8.8.8.8
sudo nano /etc/resolv.conf
# Make sure your traffic isn't redirecting
sudo nano /etc/hosts
```

- Check sudoers for wrongdoings

```
# There should be no "NOPASSWD"
sudo visudo
# Make sure all administrators are in group sudo, look for unauthorized users
sudo ls /etc/sudoers.d/
```

- Install rootkit and malware scanning tools (credit)

```
sudo apt-get install -y chkrootkit rkhunter
# rkhunter usage:
sudo rkhunter --update
sudo rkhunter --propupd
sudo rkhunter -c --enable all --disable none
# chkrootkit usage:
sudo chkrootkit -q
# Visit http://www.chkrootkit.org/README for more
# clamav usage:
# Update clamav
sudo freshclam
# Scan a directory recursively and ring a bell if something is found
clamscan -r --bell -i /home/user/
# Scan the whole system (NOT recommended!)
clamscan -r --remove /
# Safest option:
sudo apt-get install clamtk
sudo clamtk
```

- Optional: Secure apache
- Optional: Run Lynis AV (credit)

```
wget https://downloads.cisofy.com/lynis/lynis-2.6.9.tar.gz -O lynis.tar.gz
sudo tar -xzf ./lynis.tar.gz --directory /usr/share/
cd /usr/share/lynis
/usr/share/lynis/lynis update info
/usr/share/lynis/lynis audit system
```

- Secure sysctl (credit)

```
sudo sysctl -w net.ipv4.tcp_syncookies=1
sudo sysctl -w net.ipv4.ip_forward=0
sudo sysctl -w net.ipv4.conf.all.send_redirects=0
sudo sysctl -w net.ipv4.conf.default.send_redirects=0
sudo sysctl -w net.ipv4.conf.all.accept_redirects=0
sudo sysctl -w net.ipv4.conf.default.accept_redirects=0
sudo sysctl -w net.ipv4.conf.all.secure_redirects=0
sudo sysctl -w net.ipv4.conf.default.secure_redirects=0
sudo sysctl -p
```

- Look through running processes

```
ps -ax
htop
```

- Check config files for important services, there's almost always atleast one point (MySQL, SSH, Apache, README software)
- Look for illegitimate services

```
sudo service --status-all
```

- Check the installed packages list for hacking tools

```
apt list --installed
```

- Stop services (credit)

```
# DO NOT STOP ALL OF THESE WITHOUT READING THE README OR UNDERSTANDING WHAT YOU'RE ABOUT TO DO!
service sshd stop
service telnet stop # Remote Desktop Protocol
service vsftpd stop # FTP server
service snmp stop # Type of email server
service pop3 stop # Type of email server
service icmp stop # Router communication protocol
service sendmail stop # Type of email server
service dovecot stop # Type of email server
service --status-all | grep "+" # shows programs with a return code of 0 (C/C++ users will understand), which is non-native programs


* Disable Remote Desktop
```